

WEB SECURITY LABS

Beginner's Guide to IDOR

1. What is IDOR?

Insecure Direct Object Reference (IDOR) occurs when applications expose internal object references such as IDs without proper authorization checks.

2. How IDOR Works

Applications expose object identifiers in URLs.

The server trusts user-supplied IDs.

Attackers modify the ID to access another user's data.

3. Vulnerable URL Example

/profile?id=101

4. Classic ID Manipulation Example

Original Request:

/profile?id=101

Modified Request:

/profile?id=102

Without authorization validation, another user's profile becomes accessible.

5. Request Flow & Broken Access Control

[User Browser] → Requests own profile

[Vulnerable Web Application] → Reads ID directly from URL

[Database] → Returns requested profile

[Unauthorized Access] → Another user's data becomes visible

6. Risks & Impacts

Exposure of personal information

Unauthorized account access

Privacy violations

Horizontal privilege escalation

Business logic abuse

7. Prevention & Mitigation

INSECURE:

GET /profile?id=102

SECURE:

Server verifies ownership before returning data.

Use authorization checks, UUIDs, and access control middleware.

EDUCATIONAL DISCLAIMER & NOTICE

These sandbox labs are designed solely for safe, local cybersecurity education. Never test, scan, or attack systems you do not own or have explicit authorization to assess. Unauthorized testing is illegal.